

Aula 1 (Módulo 14) — Hipótese, Baseline e Comportamento Anômalo

1. Threat Hunting vs. Triagem de Alerta — a diferença fundamental

No Módulo 08, tudo começava com um **alerta** já disparado por uma regra automática. **Threat Hunting** inverte isso: o analista parte de uma **hipótese própria** — "talvez algo esteja acontecendo que nenhuma regra detecta ainda" — e vai procurar ativamente, sem esperar notificação nenhuma.

```
Triagem de Alerta:  Regra dispara → Analista investigthreat
Threat Hunting:    Analista formula hipótese → Analista investiga →
                   (se confirmar algo real) → Cria uma NOVA regra
                   para detectar automaticamente da próxima vez
```

Por que isso existe: lembra do False Negative do Módulo 08, Aula 2 — ataque real, sem alerta nenhum? Threat Hunting é a defesa contra exatamente esse cenário: atacantes sofisticados são bons em evitar regras conhecidas (lembra da Pirâmide da Dor, Módulo 12?) — Threat Hunting é como você encontra o que passou "por baixo do radar".

2. De onde vem uma boa hipótese

Uma hipótese de hunting normalmente nasce de:

- **Threat Intelligence** (Módulo 12): "um grupo conhecido por atacar o nosso setor usa a técnica X — será que já vemos sinais disso aqui?"
- **MITRE ATT&CK** (Módulo 13): "ainda não temos nenhuma detecção cobrindo a tática de Lateral Movement — vamos caçar manualmente enquanto isso não existe."
- **Anomalias observadas casualmente:** um analista percebe, sem alerta nenhum, algo "estranho" enquanto investigava outra coisa, e decide puxar esse fio.
- **Lições de incidentes anteriores:** "da última vez, o atacante também fez X antes de Y — vamos verificar se isso está acontecendo de novo em outro lugar."

Uma hipótese boa é **específica e testável**, não vaga:

```
Ruim:  "será que tem algo suspeito na rede?"
Boa:   "será que existe algum processo se comunicando com servidores
       DNS diferentes do servidor DNS corporativo configurado?"
```

3. Baseline — a base de tudo

Baseline é entender **o que é normal** naquele ambiente específico, antes de conseguir reconhecer o que é anômalo. Já mencionamos essa ideia várias vezes de forma implícita (Módulo 01, Aula 5: "uma saída vazia também é linha de base"; Módulo 08, Aula 1: "um scanner autorizado gerando tráfego 'suspeito' todo dia às 2h").

Por que baseline é difícil e essencial: o mesmo comportamento pode ser normal em um ambiente e extremamente suspeito em outro — um servidor que faz milhares de conexões de saída por minuto pode ser completamente normal se for um proxy corporativo, e um sinal grave de comprometimento se for uma estação de trabalho comum. **Sem baseline, não existe anomalia** — você não consegue reconhecer um desvio de algo que nunca definiu.

Formas práticas de construir baseline:

- Consultar volumes históricos no SIEM (Módulo 09): "quantas conexões esse tipo de host normalmente faz por dia?"
- Conversar com times de TI/infraestrutura: "esse comportamento é esperado para esse sistema?"
- Comparar múltiplos hosts do mesmo tipo entre si: "os outros 50 servidores parecidos fazem isso também, ou só este um?"

4. Comportamento normal vs. anômalo — pensando em outliers

Com um baseline estabelecido, a caça é literalmente procurar **outliers** — o que foge do padrão. Algumas perguntas estruturadas úteis:

- "Qual processo/host faz isso **com menos frequência** que todos os outros parecidos?" (raridade)
- "Qual processo/host faz isso **em um horário** diferente do padrão normal?" (temporal)
- "Qual comando/command line é **único** — nunca visto em nenhum outro lugar do ambiente?" (unicidade)

Essas três perguntas (raridade, temporal, unicidade) são, na prática, o motor de praticamente toda técnica de hunting orientada a dados.

5. TTP-driven hunting (conectando com o Módulo 13)

Uma das formas mais estruturadas de fazer hunting é escolher **uma técnica específica do ATT&CK** e caçar **todas as formas conhecidas** de evidência dela no ambiente — mesmo sem nenhum alerta apontando para lá.

Exemplo: escolher `T1053.005` (Scheduled Task, Módulo 02, Aula 3) e:

1. Listar TODAS as tarefas agendadas em TODOS os hosts (não só os que geraram alerta)
2. Comparar contra uma lista de tarefas "esperadas" (as que o próprio Windows/software legítimo cria)
3. Investigar qualquer tarefa fora dessa lista esperada — mesmo que nenhuma delas tenha disparado alerta nenhum

6. Query, pivot e timeline — as três ferramentas mentais

- **Query:** a pergunta formal que você faz ao SIEM/EDR/logs — a tradução técnica da sua hipótese em uma busca real.
- **Pivot:** a partir de um resultado interessante, "virar" a investigação para uma pergunta relacionada — ex.: encontrou um processo raro? Pivote para "que outros hosts também tiveram esse mesmo processo?", ou "esse mesmo usuário fez algo incomum em outro lugar?".
- **Timeline:** reconstruir a **ordem cronológica** dos eventos relacionados — essencial para entender causa e efeito (o que aconteceu **antes** do quê).

Query inicial → resultado interessante → PIVOT (nova pergunta relacionada) → mais resultados → monta TIMELINE → conclusão

7. Conectando tudo

Hipótese (de onde vem: TI, ATT&CK, anomalia casual, lição aprendida)
↓
Baseline (o que é normal ANTES de procurar o anômalo)
↓
Busca por outliers (raridade, temporal, unicidade) OU TTP-driven
↓
Query → Pivot → Timeline
↓
Se confirmar algo real → vira incidente (Módulo 15) E gera uma NOVA regra de detecção (Módulo 21), para que da próxima vez esse padrão já dispare alerta automaticamente

8. Recapitulando

- Threat Hunting parte de hipótese própria, não de alerta — a defesa contra ataques que evitam detecção conhecida.
- Baseline (o que é normal) é pré-requisito para reconhecer qualquer anomalia.
- Raridade, padrão temporal e unicidade são os três eixos mais comuns de busca por outliers.
- TTP-driven hunting escolhe uma técnica ATT&CK e caça evidência dela em todo o ambiente, proativamente.
- Query → Pivot → Timeline é o ciclo mental de qualquer investigação de hunting.

Próxima aula (fecha o Módulo 14)

Como conduzir uma caça guiada de verdade — e, como no Módulo 08, o convite para praticar hunting ao vivo comigo, com hipóteses reais.

Fontes recomendadas

- **SANS — "A Practical Model for Conducting Cyber Threat Hunting"** (referência amplamente citada na indústria — SANS é uma organização de treinamento em segurança bem estabelecida, mas este é um whitepaper, não um padrão oficial de governo/normatização): consulte o site oficial sans.org para a versão mais atual.
- **MITRE ATT&CK — "Detection"** (seção presente em cada página de técnica, já mencionada no Módulo 13): base direta para hunting orientado a TTP. <https://attack.mitre.org/>